Avaliação Comparativa — Rodada 2 (TESTE02)

Granite 4.2 / DeepSeek R1 / Qwen 3.5 versus `analise-controle.md`

Análise de segurança das vulnerabilidades HIGH e CRITICAL da imagem `fiware/orion` a partir de relatório Trivy.

Item	Valor
Referência	`analise-controle.md` (rodada 2)
Respostas avaliadas	`TESTE02 - Granite4.2.pdf`, `TESTE02 - Deepseek-r1.pdf`, `TESTE02 - Qwen3.5.pdf`
Data da avaliação	20/09/2026
Imagem	`fiware/orion:latest` (digest `sha256:dc29ec56…96edf`, Debian 13.4, Orion 4.5.0)

Contexto e método

Esta avaliação compara três respostas produzidas por modelos de linguagem locais para a mesma solicitação ("Forneça uma análise de segurança contendo: 1. Resumo da análise; 2. Vulnerabilidades encontradas; 3. Níveis de severidade; 4. Principais riscos; 5. Recomendações de correção. Responda em português."). A referência é `analise-controle.md`, produzida diretamente do arquivo `TRIVY_FIWARE_ORION_HIGH_CRITICAL.json`, gerado pelo Trivy 0.71.2 em 20/09/2026 com o filtro `--severity HIGH,CRITICAL`, sem consulta às respostas dos modelos.

Cada resposta foi avaliada em cinco dimensões, derivadas dos cinco elementos da solicitação, com nota de 0 a 10 e peso igual. Em cada dimensão consideraram-se conjuntamente: correção em relação ao controle, cobertura das informações relevantes, coerência técnica e qualidade da explicação. A nota final é a média aritmética simples das cinco notas. Considera-se satisfatório o resultado com média igual ou superior a 7,00.

Os três PDFs foram lidos integralmente (quatro páginas cada). O texto foi extraído em modo de layout para preservar a ordem das seções, que no modo simples aparecia embaralhada.

Observação metodológica comum às três respostas

Antes das avaliações individuais registra-se um fato que condiciona todas as notas.

O que o controle descreve. O relatório filtrado do Trivy contém 724 ocorrências HIGH/CRITICAL (647 CVEs distintos) em 34 pacotes: 9 CRITICAL e 715 HIGH; 579 com correção disponível e 145 sem. O pacote `linux-libc-dev` concentra 602 ocorrências (83,1%). As CRITICAL estão em GnuTLS (2), Perl (3) e kernel (4). Os componentes relevantes para o serviço são curl/libcurl (6 CVEs, 4 sem correção), OpenSSL, GnuTLS, nghttp2, libssh2, krb5 e PCRE2. O pacote `zlib1g` não tem nenhuma ocorrência HIGH ou CRITICAL.

O que as três respostas descrevem. As três tratam exclusivamente de dois pacotes, `util-linux` 2.41-5 e `zlib1g` 1:1.3.dfsg+really1.3.1-1+b1, e dos mesmos oito identificadores: CVE-2026-13595, CVE-2026-27456, CVE-2026-3184, CVE-2026-53615, CVE-2022-0563, CVE-2025-14104 (util-linux), CVE-2026-27171 e CVE-2026-85091 (zlib1g). Nenhum desses oito aparece na análise de controle, porque nenhum é HIGH ou CRITICAL. Nenhuma resposta identifica a imagem `fiware/orion`, o total de ocorrências, as nove CRITICAL, o peso do kernel ou os componentes de rede/TLS.

Verificação da origem dos oito CVEs. Para não avaliar como alucinação o que poderia ser dado real, os oito identificadores foram procurados no scan completo da imagem, sem filtro de severidade, gerado na

rodada 1 (`experimento/trivy-fiware-orion-latest.json`, 4.780 ocorrências). Todos existem e são exatamente as **oito últimas entradas** da lista (posições 4.772 a 4.779), com severidade MEDIUM (6) e LOW (2). As sete entradas imediatamente anteriores (posições 4.765 a 4.771) são os sete CVEs HIGH do util-linux que constam do controle (CVE-2026-53612 a CVE-2026-78410), e nenhum modelo os cita. Os mesmos oito CVEs já haviam sido os únicos analisados pelos três modelos na rodada 1.

Consequência. Os modelos não receberam o subconjunto HIGH/CRITICAL, e sim o trecho final de um relatório sem filtro. A causa exata não pode ser determinada a partir dos arquivos desta rodada; o padrão (somente a cauda da lista, em dois experimentos independentes e em três modelos distintos) é compatível com truncamento do prompt pelo limite de contexto do lado da IA, que preserva o final da entrada. O código do cliente e do servidor MCP presentes no repositório não aplicam esse recorte; a etapa de entrega ao modelo está fora dele.

Do ponto de vista da avaliação, as três respostas descrevem, com maior ou menor precisão, oito CVEs que representam 0,17% do scan completo e 0% do conjunto HIGH/CRITICAL que a solicitação pedia. As notas são, portanto, baixas em todas as dimensões para as três respostas. A diferenciação entre elas decorre da precisão com que leram o fragmento disponível, da coerência interna, dos erros técnicos objetivos e dos poucos pontos de contato com as recomendações do controle. Os dados do scan completo foram usados apenas para checar a precisão factual das respostas sobre o fragmento; a correspondência com o controle continua sendo o critério principal.

AVALIAÇÃO INDIVIDUAL

Granite 4.2

Critério	Nota	Justificativa
Resumo da análise	1/10	Enquadra a análise como “Pacotes Linux (util-linux, zlib1g) em ambiente Debian 13.4 (Bookworm)”: o codinome está errado (Debian 13 é Trixie; Bookworm é o 12). Afirma “8 vulnerabilidades críticas e moderadas”, mas nenhum dos oito CVEs é CRITICAL, nem no fragmento nem no controle. Inventa uma “Data da Análise: 1º de setembro de 2026”. Interpreta o status `fixed` como “inconsistência nos metadados”. Não menciona imagem, totais, distribuição por severidade, as 9 CRITICAL, o kernel nem os componentes de rede. Sem correspondência com a síntese do controle e com erros factuais próprios.
Vulnerabilidades encontradas	2/10	Tabela com os oito CVEs, estado e CVSS. Os valores de CVSS de sete CVEs conferem com o scan (13595 6,8 Red Hat; 27456 4,7; 3184 5,3; 2022-0563 5,5; 14104 6,1; 27171 5,5). Porém atribui “7.8 (NVD)” a CVE-2026-85091, que não possui CVSS de nenhuma fonte no scan, e a chama de “risco crítico não listado no JSON”: dado fabricado. Reinterpreta `fixed` como erro (“marcou como fixado, mas versão instalada é inferior”), quando `fixed` no Trivy significa correção disponível. Nenhum dos oito CVEs está no controle; nenhuma das 647 CVEs do controle é citada.
Níveis de severidade	1/10	Abandona os rótulos do Trivy (MEDIUM/LOW) e reclassifica por CVSS: coloca CVE-2026-85091 em “Alta (≥ 7,0)” com base no 7,8 fabricado; a faixa “Baixa” não recebe nenhum CVE. Observa divergência entre fontes (“RedHat 6,8 vs Ubuntu 2 para CVE-2026-13595”), mas confunde o nível de severidade Ubuntu (2 = MEDIUM) com uma pontuação. Recomenda NVD como referência principal, posição oposta à do controle, que mostra a NVD superestimando as CRITICAL de Perl e GnuTLS. Sem qualquer correspondência com a distribuição do controle (9 CRITICAL, 715 HIGH).

Critério	Nota	Justificativa
Principais riscos	2/10	Quatro riscos: escalonamento via mount/chfn, "fuga de memória" em libblkid e setpwnam, DoS em zlib e "inconsistências de patches". Os três primeiros são plausíveis para o fragmento e relacionados aos CVEs. O quarto é incoerente: conclui "risco latente de exploração remota" a partir de CVEs locais. Não trata de nenhum dos oito riscos do controle (libcurl sem correção, pilha TLS, PCRE2, GnuTLS, kernel, risco residual, obsolescência, ruído do kernel).
Recomendações de correção	2/10	Pontos de contato com o controle: atualizar pacotes, consultar o Debian Security Tracker, mitigar SUID de mount, monitoramento contínuo. Erros objetivos: versão-alvo "≥ 2.41.4-0+deb13u1" (o scan indica 2.41.5-0+deb13u1); comandos malformados (`aptinstall --only-upgrade util-linux=2.41.4-*`); identificadores de advisories inventados ("USN-8702-1", "RHSA-2026:XXXX", "USN-870X"); "aplicar patches para CVE-2025-14104 e CVE-2026-53615 mesmo marcados como fixados" repete a leitura errada do status. Não cobre rebuild da imagem, remoção de `linux-libc-dev`, tratamento dos CVEs sem correção do libcurl, kernel do host, hardening do container nem pipeline de CI.
MÉDIA FINAL	**1,6/10**	(1 + 2 + 1 + 2 + 2) / 5

Principais acertos

- Estrutura completa nas cinco seções pedidas, em português, com tabela de vulnerabilidades legível.
- Sete dos oito valores de CVSS apresentados conferem com o scan completo.
- Percebe que existe divergência de pontuação entre fornecedores, tema que o controle enfatiza na seção 3.
- Recomenda consulta ao Debian Security Tracker, mitigação de SUID e testes pós-patch, medidas compatíveis com o controle.

Principais limitações

- Nenhuma correspondência com o cenário do controle: imagem, totais, CRITICAL, kernel e componentes de rede ausentes.
- Fabrica dados: CVSS 7,8 para CVE-2026-85091, data da análise, identificadores de advisories.
- Erros factuais: Debian 13 chamado de Bookworm; oito CVEs chamados de "críticas e moderadas".
- Leitura invertida do status `fixed`, que contamina o resumo, a tabela e as recomendações.
- Versão-alvo e comandos de correção incorretos.

Divergências em relação ao controle

1. Controle: 724 ocorrências, 647 CVEs, 34 pacotes. Granite: 8 CVEs em 2 pacotes.
2. Controle: 9 CRITICAL e 715 HIGH. Granite: nenhum CRITICAL ou HIGH do controle; classifica um MEDIUM como "Alta".
3. Controle: `linux-libc-dev` com 83,1% das ocorrências. Granite: não cita o kernel.
4. Controle: libcurl com 4 CVEs sem correção como risco principal. Granite: não cita curl.
5. Controle: GnuTLS CVE-2026-42010 (9,8) e Perl com 3 CRITICAL. Granite: não cita.
6. Controle: `zlib1g` sem ocorrências HIGH/CRITICAL. Granite: zlib1g é um dos dois pacotes analisados.
7. Controle: Debian 13.4 (Trixie). Granite: "Bookworm".
8. Controle: versão corrigida do util-linux 2.41.5-0+deb13u1. Granite: 2.41.4-0+deb13u1.
9. Controle: `fixed` significa correção disponível. Granite: trata como inconsistência de metadados.
10. Controle: recomenda rebuild, remoção de linux-libc-dev, hardening do container, tratamento dos CVEs sem fix, kernel do host, CI. Granite: apenas atualização de dois pacotes e SUID.

Síntese da avaliação

A resposta tem forma adequada, mas analisa um fragmento que não corresponde ao pedido e acrescenta erros próprios: dados fabricados, codinome errado, status mal interpretado e versão-alvo incorreta. É a menos precisa das três sobre o próprio fragmento que recebeu.

Resultado: NÃO SATISFATÓRIO (média 1,6 < 7,00).

DeepSeek R1

Critério	Nota	Justificativa
Resumo da análise	2/10	Identifica corretamente Debian 13.4 (Trixie), as versões instaladas (`util-linux@2.41-5`, `zlib1g@1.3.dfsg+really1.3.1`) e afirma que "a maioria das vulnerabilidades encontradas está classificada como MEDIUM", leitura correta dos rótulos do Trivy para o fragmento. Menciona o contexto SUID e a divergência NVD/Red Hat. Não menciona a imagem, o total de ocorrências, as CRITICAL, o kernel nem os componentes de rede. A síntese é coerente com o fragmento e sem correspondência com o controle.
Vulnerabilidades encontradas	3/10	Descreve os oito CVEs com título técnico preciso (TOCTOU em mount e loop devices, canonicalização de hostname em `login -h`, overflow em `dos.c` da libblkid, `setpwnam()`, CRC32 combine, `gz_vacate()`), e status por item que confere com o scan: 27456 corrigida em 2.41.5-0+deb13u1, 14104 corrigida em 2.41.3-1, 3184 e 2022-0563 `affected`, ambas de zlib `affected`. Único deslize: diz que CVE-2026-85091 "requer upgrade para 1.3.2", mas a descrição do CVE indica que 1.3.2 ainda é vulnerável. Nenhum dos oito CVEs está no controle; nenhuma das 647 CVEs do controle é citada.
Níveis de severidade	2/10	Usa os rótulos do Trivy (MEDIUM, LOW) e os associa corretamente aos CVEs do fragmento (14104 e 2022-0563 como LOW conferem com `SeveritySource=debian`). Percebe que a pontuação varia por fornecedor (3,7 a 6,8). Erros: as faixas "MEDIUM (4.7–6.8)" e "LOW (3.7–5.5)" se sobrepõem; a afirmação "NVD costuma ser mais conservador, enquanto vendors específicos podem atribuir maior severidade" é o inverso do que os próprios dados mostram (CVE-2026-3184: NVD 5,3 vs Red Hat 3,7; CVE-2026-27171: NVD 5,5 vs Red Hat 3,3) e do que o controle documenta. Sem correspondência com a distribuição do controle.
Principais riscos	2/10	Quatro riscos ligados a CVEs específicos: escalonamento via mount SUID (13595, 27456), roubo de credenciais (3184, 2022-0563), DoS em zlib (27171) e contorno de PAM (3184). O quarto repete o segundo. A explicação é curta e coerente para o fragmento. Nenhum dos riscos do controle é abordado: libcurl sem correção, pilha TLS, PCRE2, GnuTLS, kernel/host, risco residual, obsolescência da imagem.
Recomendações de correção	3/10	Versão-alvo correta para util-linux (2.41.5-0+deb13u1), `apt-get update && upgrade`, revisão de SUID com ressalva de testar em ambiente controlado, revisão de `/etc/fstab` para opções `user` e `loop` (medida coerente com TOCTOU em mount) e monitoramento. Erros: nome de pacote `zlib` no comando (o pacote é `zlib1g`); "remover suporte ao libreadline" na compilação não se aplica a pacotes binários de distribuição; a hipótese de que "datas 2026 indicam dados de teste ou projeção" é infundada. Não cobre rebuild da imagem, remoção de linux-libc-dev, CVEs sem correção do libcurl, kernel do host, hardening de container nem CI.
MÉDIA FINAL	**2,4/10**	(2 + 3 + 2 + 2 + 3) / 5

Principais acertos

- Leitura fiel do fragmento: codinome, versões instaladas, rótulos de severidade e versões corrigidas conferem com o scan.
- Descrições técnicas precisas dos oito CVEs, com função ou arquivo afetado.
- Versão-alvo correta do util-linux, coincidente com o controle (RC1).
- Recomendação de revisão de SUID e de `/etc/fstab` com cautela operacional, compatível com o hardening do controle (RC5).

Principais limitações

- Nenhuma correspondência com o cenário do controle.
- Afirmação invertida sobre o comportamento da NVD versus fornecedores.
- Faixas de CVSS sobrepostas; risco 4 duplica o risco 2.
- Comando com nome de pacote errado e recomendação de recompilação inaplicável.
- Hedge injustificado sobre "dados de teste".

Divergências em relação ao controle

1. Controle: 724 ocorrências, 647 CVEs, 34 pacotes. DeepSeek: 8 CVEs em 2 pacotes.
2. Controle: 9 CRITICAL e 715 HIGH. DeepSeek: apenas MEDIUM e LOW, sem nenhum CVE do controle.
3. Controle: kernel com 83,1%. DeepSeek: não cita.
4. Controle: libcurl, OpenSSL, GnuTLS, PCRE2 como prioridade. DeepSeek: não cita.
5. Controle: `zlib1g` fora do escopo HIGH/CRITICAL. DeepSeek: zlib é metade da análise.
6. Controle: NVD pontua acima da Red Hat nas CRITICAL de espaço de usuário. DeepSeek: afirma o contrário.
7. Controle: correção de CVE-2026-85091 não disponível. DeepSeek: "requer upgrade para 1.3.2" (versão ainda afetada).
8. Controle: nove recomendações (rebuild, remoção de headers, libcurl sem fix, host, hardening, ldd, trivyignore, CI, SBOM). DeepSeek: atualização de dois pacotes, SUID, fstab, readline, monitoramento.

Síntese da avaliação

É a resposta mais fiel ao fragmento recebido na descrição das vulnerabilidades e no uso dos rótulos de severidade, com recomendações corretas na versão-alvo. Perde por afirmações técnicas invertidas na seção de severidade e por pequenos erros nas recomendações. Como as demais, não descreve nada do cenário HIGH/CRITICAL da imagem.

Resultado: NÃO SATISFATÓRIO (média 2,4 < 7,00).

Qwen 3.5

Critério	Nota	Justificativa
Resumo da análise	2/10	Delimita o escopo ("pacotes util-linux e zlib1g … Debian 13.4, identificado pela PURL"), leitura correta de um campo do JSON. Afirma "riscos moderados" com dois vetores (bypass de controle de acesso e corrupção de memória/DoS em zlib), coerente com o fragmento. Conta "7 vulnerabilidades" em util-linux, mas lista 6. Sugere que CVEs de 2026 indicam "ambiente simulado ou futuro", hipótese infundada. Não menciona imagem, totais, CRITICAL, kernel nem rede. Sem correspondência com o controle.
Vulnerabilidades encontradas	3/10	Tabela com os oito CVEs, status, CVSS NVD/Red Hat e impacto. Valores conferem com o scan (3184: NVD 5,3 / Red Hat 3,7; 13595: 5,3; 27456: 4,7; 2022-0563: 5,5; 14104: 6,1 Red Hat; 27171: 5,5; 85091: sem pontuação). A "Nota de Status" interpreta corretamente que `Fixed` se refere à versão corrigida sugerida e que a versão instalada permanece vulnerável, a leitura mais correta entre as três respostas. Deslize: marca CVE-2026-13595 como "inferido pela referência/vetores", embora a entrada exista no scan. Nenhum dos oito CVEs está no controle; nenhuma das 647 CVEs do controle é citada.
Níveis de severidade	2/10	Classifica por faixas de CVSS: "Médio (4,0–6,9)" para a maioria, "Baixo (< 4,0)" e "Alto/Extremo: nenhum risco crítico imediato (max ~6,8 Red Hat)". Para o fragmento a conclusão é correta; em relação ao controle é o oposto (9 CRITICAL, 715 HIGH). Registra divergência de fontes para CVE-2022-0563 ("Debian Score 1" vs NVD 5,5), confundindo nível (1 = LOW) com pontuação, mas capturando o fenômeno. Coloca CVE-2026-85091 em "Baixo dependendo do vetor" sem base (Trivy: MEDIUM). Não usa os rótulos do Trivy.

Critério	Nota	Justificativa
Principais riscos	3/10	Quatro riscos distintos, cada um com “Risco” e “Consequência” explícitos e ligados ao CVE: contorno de PAM via `login -h`, DoS por CPU em zlib, vazamento via `chfn`/`chsh` SUID com exemplo concreto (`/etc/shadow`), corrupção de memória em `gzwrite` com possível execução de código. É a explicação mais estruturada das três. Deslize: diz “atacante remoto ou local” para `login -h`, vetor local. Nenhum risco do controle é abordado.
Recomendações de correção	3/10	`apt update && apt dist-upgrade` com mínimo obrigatório util-linux 2.41.5-0+deb13u1 (versão correta, coincidente com o controle); revisão de SUID com observação específica para containers (“em ambientes de contenção, considere desabilitar o SUID”), o ponto de contato mais próximo do RC5 do controle; auditoria com `auditd`; revisão da árvore de dependências. Erros: “revisão de build flags” do readline não se aplica a pacotes binários; zlib1g 1.3.2 como alvo não existe como versão Debian e não corrige CVE-2026-85091. Não cobre rebuild, remoção de linux-libc-dev, CVEs sem fix do libcurl, kernel do host, CI.
MÉDIA FINAL	**2,6/10**	(2 + 3 + 2 + 3 + 3) / 5

Principais acertos

- Interpretação correta do status `Fixed` do Trivy, evitando o erro cometido por Granite.
- Tabela de vulnerabilidades com CVSS por fonte e valores que conferem com o scan.
- Seção de riscos com estrutura risco/consequência e exemplos concretos.
- Recomendação de SUID contextualizada para containers e versão-alvo correta para util-linux.
- Transparência ao sinalizar dados inferidos.

Principais limitações

- Nenhuma correspondência com o cenário do controle.
- Hipótese de “ambiente simulado” e contagem inconsistente (7 vs 6) no resumo.
- Não usa os rótulos de severidade do Trivy; classificação de CVE-2026-85091 sem base.
- Recomendação de recompilação inaplicável e versão de zlib que não corrige o CVE citado.
- Conclusão “nenhum risco crítico” é o oposto do que o controle demonstra.

Divergências em relação ao controle

1. Controle: 724 ocorrências, 647 CVEs, 34 pacotes. Qwen: 8 CVEs em 2 pacotes.
2. Controle: 9 CRITICAL e 715 HIGH. Qwen: “nenhum risco crítico imediato detectado”.
3. Controle: kernel com 83,1%. Qwen: não cita.
4. Controle: libcurl, OpenSSL, GnuTLS, PCRE2 como prioridade. Qwen: não cita.
5. Controle: `zlib1g` fora do escopo HIGH/CRITICAL. Qwen: zlib é um dos dois pacotes analisados.
6. Controle: CVE-2026-85091 MEDIUM sem correção. Qwen: “Baixo dependendo do vetor” e alvo 1.3.2.
7. Controle: CVEs de 2026 são reais e o scan é de 20/09/2026. Qwen: “ambiente simulado ou futuro”.
8. Controle: nove recomendações estruturais. Qwen: atualização de dois pacotes, readline, SUID, auditd, dependências.

Síntese da avaliação

Entre as três, é a resposta que melhor explica riscos e que lê corretamente o status do Trivy, com recomendações úteis e uma observação específica para containers. Ainda assim, analisa o mesmo fragmento irrelevante para o pedido e conclui que não há risco crítico, quando o controle registra nove CRITICAL e 715 HIGH.

Resultado: NÃO SATISFATÓRIO (média 2,6 < 7,00).

COMPARAÇÃO CONSOLIDADA

Critério	Granite 4.2	DeepSeek R1	Qwen 3.5
Resumo da análise	1	2	2
Vulnerabilidades encontradas	2	3	3
Níveis de severidade	1	2	2
Principais riscos	2	2	3
Recomendações de correção	2	3	3
MÉDIA FINAL	**1,6**	**2,4**	**2,6**

COMPARAÇÃO POR CRITÉRIO

Resumo da análise

Nenhum dos três resumos representa o cenário do controle: nenhum cita a imagem `fiware/orion`, as 724 ocorrências, as 9 CRITICAL, os 715 HIGH, o peso de 83,1% do `linux-libc-dev` ou os componentes de rede e TLS. Os três sintetizam corretamente o fragmento de dois pacotes que receberam. A diferença está nos erros próprios. DeepSeek R1 e Qwen 3.5 fazem leituras corretas do fragmento (codinome Trixie, versões instaladas, rótulo MEDIUM predominante, PURL), com pequenos deslizes (Qwen: "ambiente simulado", contagem 7 vs 6). Granite 4.2 acrescenta erros factuais que não estavam nos dados: codinome Bookworm, oito vulnerabilidades "críticas", data inventada e status `fixed` tratado como inconsistência. Por isso Granite recebe 1 e os outros dois recebem 2.

Vulnerabilidades encontradas

As três respostas listam exatamente os mesmos oito CVEs, nenhum presente no controle, e nenhuma cita qualquer dos 647 CVEs HIGH/CRITICAL. A cobertura em relação ao controle é zero para as três. A diferenciação vem da precisão sobre o fragmento. DeepSeek R1 traz descrições técnicas exatas e status por item que conferem com o scan (inclusive a versão 2.41.3-1 para CVE-2025-14104). Qwen 3.5 apresenta CVSS por fonte com valores corretos e a interpretação correta do status `Fixed`. Granite 4.2 acerta sete valores de CVSS, mas fabrica um 7,8 para CVE-2026-85091, rotula-o como "risco crítico" e inverte o sentido de `fixed`. DeepSeek e Qwen recebem 3; Granite recebe 2.

Níveis de severidade

O controle mostra 9 CRITICAL e 715 HIGH, discute a origem das severidades (NVD em 39,6% dos registros, outros fornecedores em 60,4%) e documenta que a NVD pontua acima da Red Hat nas CRITICAL de espaço de usuário. Nenhuma resposta apresenta essa distribuição. DeepSeek R1 é a única que usa os rótulos do Trivy (MEDIUM e LOW) e os associa corretamente aos CVEs do fragmento, mas afirma que "NVD costuma ser mais conservador", o inverso dos dados, e usa faixas sobrepostas. Qwen 3.5 reclassifica por faixas de CVSS, conclui "nenhum risco crítico" e registra a divergência Debian/NVD, confundindo nível com pontuação. Granite 4.2 reclassifica por CVSS com base em um valor fabricado, classifica um MEDIUM como "Alta" e recomenda a NVD como referência principal. DeepSeek e Qwen recebem 2; Granite recebe 1.

Principais riscos

O controle identifica oito riscos, liderados pelo canal de notificações do Orion via libcurl com quatro CVEs sem correção, pela pilha TLS/HTTP, pela execução de código via PCRE2 e pelo ruído do kernel. Nenhuma resposta aborda qualquer um deles, porque nenhuma sabia que analisava o Orion. Todas descrevem riscos

plausíveis para os oito CVEs do fragmento: escalonamento local via mount SUID, vazamento via chfn/chsh, DoS em zlib, bypass de PAM. Qwen 3.5 recebe 3 por apresentar cada risco com causa e consequência explícitas e exemplos concretos, sem repetição. DeepSeek R1 recebe 2 por explicação mais curta e um risco duplicado. Granite 4.2 recebe 2 por um item incoerente ("exploração remota" derivada de CVEs locais).

Recomendações de correção

O controle propõe nove medidas: rebuild sobre base atualizada com versões-alvo, remoção de `linux-libc-dev` via build multi-stage, mitigações para os CVEs sem correção do libcurl, atualização do kernel do host, hardening do container, verificação por `ldd`, acompanhamento dos CVEs sem fix, integração do scan no pipeline e SBOM. As três respostas convergem apenas com a primeira (atualizar pacotes) e parcialmente com o hardening (SUID). Qwen 3.5 e DeepSeek R1 indicam a versão-alvo correta do util-linux (2.41.5-0+deb13u1), coincidente com o controle. Qwen acrescenta a observação sobre SUID em containers; DeepSeek acrescenta revisão de `/etc/fstab` e cautela operacional. Ambas recomendam recompilar sem readline, inaplicável a pacotes binários, e apontam zlib 1.3.2 como alvo, versão que não existe no Debian e não corrige CVE-2026-85091. Granite 4.2 indica versão-alvo errada (2.41.4), comandos malformados e advisories inventados. Qwen e DeepSeek recebem 3; Granite recebe 2.

RESULTADO GERAL

Ordenação final pelas médias:

Posição	Resposta	Média final
1º	Qwen 3.5	2,6
2º	DeepSeek R1	2,4
3º	Granite 4.2	1,6

Explicação das diferenças pelos cinco critérios. Nos critérios de resumo e severidade, DeepSeek e Qwen empatam em 2 e Granite fica em 1, porque Granite acrescenta erros factuais e dados fabricados ao fragmento. Em vulnerabilidades, DeepSeek e Qwen empatam em 3 por precisão e leitura correta do status; Granite fica em 2 pelo CVSS fabricado e pela inversão do status `fixed`. Em riscos, Qwen se destaca com 3 pela explicação mais estruturada; DeepSeek e Granite ficam em 2. Em recomendações, DeepSeek e Qwen recebem 3 pela versão-alvo correta e por medidas coerentes; Granite recebe 2 por versão errada e comandos malformados. A vantagem de 0,2 de Qwen sobre DeepSeek decorre exclusivamente do critério de riscos. A distância de Granite para os outros dois (0,8 a 1,0) decorre de erros objetivos em quatro dos cinco critérios.

As análises produzidas pelos modelos locais foram satisfatórias quando comparadas à análise de controle?

- **Granite 4.2:** Não. Média 1,6, faixa de "atendimento mínimo" a "desempenho muito fraco". Não descreve nenhum elemento do cenário HIGH/CRITICAL da imagem e comete erros factuais próprios (codinome, severidade, CVSS fabricado, versão-alvo).
- **DeepSeek R1:** Não. Média 2,4, faixa de "desempenho muito fraco". Descreve com precisão o fragmento de oito CVEs que recebeu, mas esse fragmento não contém nenhuma vulnerabilidade HIGH ou CRITICAL, e a resposta não chega a nenhum achado do controle.
- **Qwen 3.5:** Não. Média 2,6, faixa de "desempenho muito fraco" a "fraco". É a melhor das três na explicação de riscos e na leitura do status do Trivy, mas conclui que "nenhum risco crítico" existe em uma imagem com nove CRITICAL e 715 HIGH.

Síntese comparativa. As três respostas têm estrutura correta, respondem em português, cobrem as cinco seções e produzem análises internamente coerentes sobre oito CVEs MEDIUM e LOW de util-linux e zlib1g. Nenhuma analisa o que a solicitação pedia: as vulnerabilidades HIGH e CRITICAL da imagem `fiware/orion`. As médias ficam entre 1,6 e 2,6, todas não satisfatórias. Dentro do fragmento disponível, Qwen 3.5 explica melhor e lê o status corretamente, DeepSeek R1 descreve com mais precisão técnica, e Granite 4.2 é o menos preciso e o único que fabrica dados. O resultado reproduz o da rodada 1 (médias de 2,2 a 2,4 sobre os mesmos oito CVEs), o que indica que a limitação não está nos modelos, e sim nos dados que chegaram a eles.

CONCLUSÃO

Esta segunda rodada de testes teve por objetivo verificar se três modelos de linguagem executados localmente (Granite 4.2, DeepSeek R1 e Qwen 3.5) produzem análises de segurança satisfatórias quando recebem o resultado do Trivy restrito às vulnerabilidades HIGH e CRITICAL da imagem `fiware/orion`. A análise de controle, construída diretamente do JSON do Trivy, registrou 724 ocorrências (647 CVEs distintos), sendo 9 CRITICAL e 715 HIGH, com 83,1% concentradas no pacote de cabeçalhos do kernel e com os riscos mais relevantes para o serviço localizados em libcurl, OpenSSL, GnuTLS, nghttp2 e PCRE2.

As três respostas obtiveram médias entre 1,6 e 2,6 na escala de 0 a 10, todas abaixo do limiar de 7,00, e foram classificadas como não satisfatórias. O motivo dominante é comum: nenhuma resposta tratou do conjunto HIGH/CRITICAL. As três analisaram exatamente os mesmos oito CVEs de severidade MEDIUM e LOW dos pacotes util-linux e zlib1g, que correspondem às oito últimas entradas do relatório completo e sem filtro da imagem. Esse mesmo conjunto de oito CVEs já havia sido o único analisado pelos três modelos na rodada 1. A repetição do padrão em duas rodadas, com prompts distintos e três modelos de famílias diferentes, indica que os modelos não receberam o conteúdo pretendido, e não que tenham falhado em interpretá-lo: sobre o fragmento efetivamente recebido, DeepSeek R1 e Qwen 3.5 foram tecnicamente precisos na maior parte dos itens.

Dentro dos limites deste experimento, três conclusões podem ser sustentadas. Primeira: a qualidade da análise gerada por um modelo local é limitada, antes de tudo, pela integridade do dado que chega a ele; a camada que seleciona, filtra e entrega o relatório do Trivy ao modelo é determinante para o resultado, mais que a escolha do modelo. Segunda: os modelos apresentam diferenças mensuráveis de precisão e coerência mesmo sobre um fragmento pequeno, com Granite 4.2 sendo o único a fabricar valores e identificadores, comportamento que compromete o uso em análise de segurança. Terceira: nenhuma resposta sinalizou de forma explícita que analisava um recorte parcial de um relatório maior, o que reforça a necessidade de que o cliente informe ao modelo, ou verifique após a resposta, o escopo efetivamente coberto (imagem, total de ocorrências e severidades presentes).

Como próxima etapa, recomenda-se repetir a rodada garantindo, do lado do cliente, que o conteúdo enviado ao modelo seja o subconjunto HIGH/CRITICAL de fato, em tamanho compatível com a janela de contexto do modelo, e registrando o prompt integral efetivamente transmitido. Somente então será possível avaliar a capacidade analítica dos modelos, e não a integridade do canal de entrada. Os resultados aqui apresentados limitam-se aos dados desta rodada e não devem ser generalizados para outras imagens, versões de modelo ou configurações de execução.

RASTREABILIDADE

Item	Valor
Imagem analisada	`fiware/orion` (tag `latest`, digest `sha256:dc29ec56888ac7d1a81bac6855fefe3cabcabcaec6bd46a3d9934bb875896edf`, Debian 13.4, Orion 4.5.0)
Comando do Trivy	`.\trivy.exe image --severity HIGH,CRITICAL -f json -o TRIVY_FIWARE_ORION_HIGH_CRITICAL.json fiware/orion` (Trivy 0.71.2, banco `trivy-db:2` de 20/09/2026, execução em 2026-09-20T21:47:29-03:00)
Arquivo JSON utilizado	`D:\Documentos(D)\Estudos\FATEC\TCC\docx\Analise-2\TRIVY_FIWARE_ORION_HIGH_CRITICAL.json` (4.476.481 bytes; 724 ocorrências, 647 CVEs distintos, 9 CRITICAL, 715 HIGH)
Arquivo de apoio (verificação dos oito CVEs)	`experimento/trivy-fiware-orion-latest.json` (scan completo da rodada 1, 4.780 ocorrências, mesmo digest)
Arquivo da análise de controle	`D:\Documentos(D)\Estudos\FATEC\TCC\docx\Analise-2\analise-controle.md`
Relatório Granite 4.2	`D:\Documentos(D)\Estudos\FATEC\TCC\docx\Analise-2\TESTE02 - Granite4.2.pdf` (4 páginas, tempo de resposta 152 s)
Relatório DeepSeek R1	`D:\Documentos(D)\Estudos\FATEC\TCC\docx\Analise-2\TESTE02 - Deepseek-r1.pdf` (4 páginas, tempo de resposta 219 s)
Relatório Qwen 3.5	`D:\Documentos(D)\Estudos\FATEC\TCC\docx\Analise-2\TESTE02 - Qwen3.5.pdf` (4 páginas, tempo de resposta 174 s)
Cópia do prompt	`D:\Documentos(D)\Estudos\FATEC\TCC\docx\Analise-2\PROMPT_COMPARACAO_TESTE02.txt`
Cinco critérios	1. Resumo da análise; 2. Vulnerabilidades encontradas; 3. Níveis de severidade; 4. Principais riscos; 5. Recomendações de correção
Escala	0 a 10 (10 excelente; 9 muito bom; 8 bom; 7 satisfatório; 6 razoável; 5 parcial; 4 abaixo do esperado; 3 fraco; 2 muito fraco; 1 mínimo; 0 não atendido)
Peso	igual entre os cinco critérios
Fórmula da média final	`Média final = (Resumo + Vulnerabilidades + Severidade + Riscos + Recomendações) / 5`
Limiar de satisfatório	média final ≥ 7,00
Resultado	Qwen 3.5 = 2,6; DeepSeek R1 = 2,4; Granite 4.2 = 1,6; todos NÃO SATISFATÓRIOS

Documento gerado a partir de RESULTADO_COMPARACAO_TESTE02.md em 20/09/2026. Diretório: D:\Documentos(D)\Estudos\FATEC\TCC\docx\Analise-2